Information Dynamics and Applications
https://www.acadlore.com/journals/IDA

A Governance and Compliance Control Framework for Medallion Architecture

Bharatsinh Narendrasinh Jhala*

Independent Researcher, Plainsboro Township, 08536 New Jersey, United States

* Correspondence: Bharatsinh Narendrasinh Jhala (reachbharatsinh@gmail.com)

Received: 05-11-2026 **Revised:** 06-15-2026 **Accepted:** 06-24-2026

Citation: B. N. Jhala, "A governance and compliance control framework for Medallion Architecture," *Inf. Dyn. Appl.*, vol. 5, no. 2, pp. 130–141, 2026. https://doi.org/10.56578/ida050205.

© 2026 by the author(s). Published by Acadlore Publishing Services Limited, Hong Kong. This article is available for free download and can be reused and cited, provided that the original published version is credited, under the CC BY 4.0 license.

Abstract: The Medallion Architecture, comprising Bronze, Silver, and Gold data layers, is widely adopted in enterprise data lakes and lakehouse platforms. However, its conventional implementation has primarily emphasized progressive data transformation, while governance and regulatory compliance requirements have often remained insufficiently specified. In regulated environments, this limitation may introduce risks associated with unauthorized data access, inadequate data quality assurance, insufficient protection of sensitive information, and unclear accountability. To address these challenges, a compliance-first governance framework was developed. Three core control dimensions were established, one per data layer: access boundaries (Bronze), data quality gates (Silver), and sensitivity-aware transformations (Gold). These layer-specific controls were complemented by cross-layer governance requirements encompassing data ownership, data lineage, and audit trails. The proposed framework was evaluated through a structured mapping of its control requirements against the technical safeguards specified in the Health Insurance Portability and Accountability Act (HIPAA) Security Rule, the security and privacy control catalog established in National Institute of Standards and Technology Special Publication 800-53 Revision 5 (NIST SP 800-53 Rev. 5), the requirements of the Federal Trade Commission (FTC) Safeguards Rule, and the data protection principles of the General Data Protection Regulation (GDPR). This mapping establishes requirement-level traceability and does not constitute empirical validation. Furthermore, a taxonomy comprising six operational failure modes was synthesized from practitioner experience in regulated data platform environments. This taxonomy was used to illustrate its applicability to operational risk scenarios. By embedding explicit governance obligations within successive data refinement layers, the proposed framework provides a systematic approach to translating regulatory and organizational requirements into implementable architectural controls. The resulting framework offers a reproducible reference architecture for strengthening data governance, supporting compliance assessments, and improving accountability in regulated enterprise data lakehouse environments.

Keywords: Medallion Architecture; Data governance; Bronze-Silver-Gold layers; Data quality gate; Access control; Data lineage; Regulated data platform; Lakehouse compliance

1 Introduction

Enterprise data platform engineering has converged on the Medallion Architecture as the predominant staging pattern for lakehouse implementations. Bronze, Silver, and Gold—the three layers of the pattern—provide a shared vocabulary for raw ingestion, conformance and cleansing, and curated consumption, respectively [1, 2]. Adoption of this vocabulary across healthcare, financial services, and government data platform programs reflects the pattern's practical utility as an engineering convention: teams working on separate data product domains immediately understand what Bronze means, what Silver promises, and what Gold is expected to deliver [3, 4].

Governance implications of those layers have received substantially less attention than their technical mechanics. Designed and documented as a transformation model, the Medallion Architecture specifies how data matures through successive refinement stages [1, 5]—not who may read each layer, what quality obligations must be satisfied before promotion between layers, what sensitivity-aware transformations are required before specific consumer populations receive Gold access, or who bears accountability when a dataset is found incorrect, over-disclosed, or undocumented. In unregulated environments, these omissions represent design decisions appropriately left to implementing organizations.

In regulated environments, practitioner experience indicates they represent an architectural deficiency with direct compliance consequences.

Regulatory instruments make the stakes concrete. The Health Insurance Portability and Accountability Act (HIPAA) Security Rule requires covered entities to implement access controls, audit controls, integrity controls, and transmission security for all electronic protected health information [6]. A Bronze layer preserving raw clinical data without defined access principles, audit logging, and separate encryption key material would be difficult to reconcile with the technical safeguards under 45 C.F.R. § 164.312. The Federal Trade Commission (FTC) Safeguards Rule requires financial institutions to implement and maintain a data classification program [7]. A Gold dataset built generically, without a named consumer population and documented transformation rationale, is difficult to defend in a regulatory examination. Article 5 of the General Data Protection Regulation (GDPR) requires that personal data be limited to what is necessary for the purposes for which it is processed [8]; serving the broadest available Gold dataset to authenticated users does not satisfy that obligation without additional architectural controls.

Components of this governance challenge have been examined in isolation across several literature streams. Data lake management research has cataloged architectural challenges, including metadata management, schema evolution, and data quality [3, 4, 9]. Data governance scholarship has identified critical success factors—stewardship, ownership, and policy enforcement—relevant to any data asset program [10]. Provenance literature has established technical requirements for traceable transformation records [11]. What the literature has not produced is a synthesis of these requirements into a compliance-first governance architecture expressed within the Medallion pattern itself—a gap indicating that the existing literature treats governance as a policy overlay rather than an architectural obligation.

This gap is distinct from the coverage already provided by general-purpose data management frameworks. DAMA International's Data Management Body of Knowledge (DAMA-DMBOK) [12], the data management profession's dominant reference framework, catalogs governance as one of several knowledge areas alongside data architecture, data quality, and metadata management, and treats each as a largely independent discipline applied across an organization's data estate; it does not specify how those disciplines attach to the specific layer boundaries of a Bronze-Silver-Gold pipeline, nor does it operationalize them as enforceable, per-layer, pipeline-level obligations. The contribution of this article is narrower and more specific than a general governance framework: it is a mapping of a subset of DAMA-DMBOK's governance, quality, and lineage disciplines onto the three Medallion layers and their cross-layer relationships, expressed as obligations enforceable by the platform's own pipeline infrastructure rather than as organizational policy applied above it.

A governance framework was constructed by operationalizing one primary obligation per Medallion layer—access boundary at Bronze, quality gate at Silver, sensitivity-aware transformation at Gold—alongside three cross-layer obligations: named ownership, lineage as a designed platform output, and a tamper-evident queryable audit trail. The framework was evaluated against HIPAA, National Institute of Standards and Technology Special Publication 800-53 Revision 5 (NIST SP 800-53 Rev. 5), the FTC Safeguards Rule, and the GDPR and grounded in a six-mode failure taxonomy informed by practitioner experience in regulated data platform environments. Sections 2 through 5 present the related work, framework design, evaluation results, and synthesis in turn. The proposed framework is summarized, with detailed specifications of the key governance controls for each layer, including the Silver-layer data quality contract and the Gold-layer transformation catalog.

2 Related Work

2.1 Lakehouse Architecture and the Medallion Pattern

Resolving the limitations of traditional data warehouses—data staleness, high total cost of ownership, and lack of native support for machine learning workloads—motivated the formalization of the lakehouse concept by Zaharia et al. [1]. Lakehouse platforms preserve raw data in open direct-access formats while providing first-class query capability over the same storage layer. Delta Lake supplied the transaction layer supporting atomicity, consistency, isolation, and durability guarantees that made this architecture viable at enterprise scale, enabling schema enforcement, time-travel queries, and atomic writes over cloud object stores [2], typically executing atop distributed processing engines such as Apache Spark [13]. These capabilities support reliable data management and provide a foundation for organizing data throughout successive processing stages. The Medallion Architecture emerged as the staging discipline naturally complementary to these transaction guarantees: Bronze for immutable raw ingestion, Silver for validated and conformed data, and Gold for curated consumption. This layered approach provides a structured progression from raw data to refined datasets for downstream use. Table 1 presents an overview of the compliance-first governance framework.

Prior literature on data lake management has cataloged schema evolution, dataset discovery, metadata management, and data quality as the primary operational challenges [4, 9]. Giebler et al. [14] identified access control, data quality, and provenance as open problems in data lake implementations but did not develop operational specifications for these obligations within the Medallion layer structure. The gap this study addresses—a compliance-first reframing of Bronze-Silver-Gold as governance architectural units—remains unoccupied in the data engineering literature.

Table 1. Compliance-first governance framework overview: layer, primary obligation, mechanism, and regulatory anchor

Layer	Primary Obligation	Key Mechanism	Regulatory Anchor
Bronze	Access boundary	Role-attribute access taxonomy; separate encryption key hierarchy; immutable storage	HIPAA, 45 C.F.R. § 164.312(a); NIST AC-2, AC-3
Silver	Quality gate	Signed quality contract (5 dimensions); promotion evidence record	HIPAA, 45 C.F.R. § 164.312(b); NIST AU-2, SI-10
Gold	Sensitivity-aware transformation	Consumer-population specification; transformation catalog; Gold audit obligation	HIPAA Minimum Necessary Standard; NIST AC-3; GDPR Art. 5
Cross-layer	Ownership + lineage + audit trail	Named owner per layer; engineered lineage output; tamper-evident trail	HIPAA, 45 C.F.R. § 164.312(b); NIST AU-11; FTC Safeguards Rule, 16 C.F.R. Part 314

Note: HIPAA = Health Insurance Portability and Accountability Act; NIST = National Institute of Standards and Technology; GDPR = General Data Protection Regulation; FTC = Federal Trade Commission; AC = Access Control; AU = Audit and Accountability; SI = System and Information Integrity.

2.2 Data Governance Frameworks in Regulated Environments

Critical success factors for enterprise data governance programs—stewardship, quality assurance, policy enforcement, access management, and ownership assignment—are well-characterized in the management information systems literature [10]. The dominant framing positions governance as a policy and process layer applied above the platform rather than expressed within it. Regulatory instruments impose a different relationship between governance and architecture.

Each regulatory regime applicable to covered entities specifies technical obligations that no policy document alone satisfies. The HIPAA Security Rule specifies access controls, audit controls, integrity controls, and transmission security for electronic protected health information [6]. NIST SP 800-53 Rev. 5 provides an authoritative control catalog spanning access control, audit and accountability, and system integrity control families, comprising more than 1,000 security and privacy controls and control enhancements organized across 20 control families [15]. The FTC Safeguards Rule requires a data classification program and a designated security officer [7]. The GDPR mandates data minimization, purpose limitation, and demonstrable compliance [8]. The growth of medical and enterprise big data has similarly outpaced the privacy and governance architectures on which earlier systems were designed, reinforcing the case for architectural rather than purely policy-based controls [16]. Meeting these obligations requires architectural expression—a constraint that the governance reframing proposed in this study is designed to satisfy.

2.3 Data Quality Models and Contract Specifications

Consumer-facing data quality—the properties that make data useful and reliable to the people and systems that depend on it—was distinguished from producer-measured data quality by Wang and Strong [17], who established the foundational taxonomy of quality dimensions: accuracy, completeness, consistency, timeliness, and contextual fit. Batini et al. [18] systematized assessment and improvement methodologies across heterogeneous data sources. Schelter et al. [19] demonstrated that quality constraint verification at a production pipeline scale is feasible through a declarative constraint application programming interface that executes unit tests for data at runtime. In regulated healthcare environments, Weiskopf and Weng [20] identified five quality dimensions relevant to electronic health record reuse through a review of 95 publications: completeness, correctness, concordance, plausibility, and currency.

The quality contract—a documented, signed assertion of what a Silver dataset claims about itself, enforceable at promotion time and retained as a governance artifact—is not an established standard in prior literature. Assessment frameworks [17, 18] and automated verification systems [19] address individual aspects but have not been synthesized into an auditable promotion mechanism for Medallion layer governance.

2.4 Data Lineage and Provenance

Herschel et al. [11] distinguished three provenance types with distinct implications for enterprise data platform compliance: why-provenance (which source tuples contributed to a result), how-provenance (how values were derived) and where-provenance (the original location of values). Regulated platforms require all three: why-provenance

supports audit questions about record inclusion, how-provenance supports questions about computed values, and where-provenance supports chain-of-custody requirements. The distinction between lineage as documentation—maintained by engineers at irregular intervals—and lineage as an engineered platform output produced automatically at each execution is derived from the potential for audit readiness; only the latter produces evidence that reflects the current platform state [11]. Sawadogo and Darmont [3] identified lineage metadata management as a primary open challenge for data lake architectures at enterprise scale.

2.5 Data Mesh, Regulatory Artificial Intelligence Frameworks, and Privacy-Enhancing Technologies

Recent literature has begun to treat data architecture governance as a first-order design concern rather than an afterthought. Goedegebuure et al. [21], synthesizing 114 industrial reports in a systematic gray literature review, characterized data mesh as a decentralized, domain-oriented alternative to centralized data platforms, in which each business domain owns and governs the data products it produces. This is a materially different governance posture from that proposed in the present study: the framework in this research operationalizes governance as a property of the Bronze-Silver-Gold pipeline within a single platform boundary, with obligations attached to layers rather than to organizational domains, and does not require an organization to first undertake the domain-decomposition and federated-ownership restructuring that data mesh adoption entails. The two approaches are complementary rather than competing: a domain team operating within a data mesh topology can apply the layer-level obligations proposed in this study inside its own data product boundary, using them as the internal architectural discipline for how that domain's Bronze, Silver, and Gold datasets are governed. Harby and Zulkernine [22] provided a more recent survey and experimental evaluation of lakehouse platforms, confirming that the governance gap identified in Section 2.1—technical mechanics without accompanying access, quality, or disclosure obligations—persists across current lakehouse implementations.

Two further developments bear on the framework's stated future scope. The NIST Artificial Intelligence Risk Management Framework [23] establishes governance expectations for artificial intelligence system trustworthiness, including data provenance and access-control requirements for training data, which extend naturally to the artificial intelligence-training-workload direction identified as future work in Section 5: a Gold dataset assembled for model training carries a consumer population—the model and its downstream deployments—whose authorization and disclosure obligations this framework's per-layer structure could specify explicitly. The Organization for Economic Co-operation and Development (OECD) survey of privacy-enhancing technologies [24] catalogs techniques, including differential privacy, secure multi-party computation, and synthetic data generation, which extend the de-identification and generalization techniques in the Gold transformation catalog, as described in NIST SP 800-188 [25], by providing additional formal privacy guarantees where required by regulatory regimes.

3 Methodology

3.1 Research Design

This study followed a design science research methodology structured according to the six-activity process model of Peffers et al. [26]. The problem identification and motivation activity analyzed regulatory instruments—the HIPAA Security Rule, NIST SP 800-53 Rev. 5, the FTC Safeguards Rule, and the GDPR—for technical safeguard requirements applicable to data platform architecture, and synthesized peer-reviewed literature on data governance, data quality, data lake management, and data provenance to establish that the Medallion Architecture, as conventionally documented, specifies data movement without specifying who may read each layer, what quality must be demonstrated before promotion, what sensitivity-aware transformation is required before access, or who is accountable for each layer's contents. The objectives-of-a-solution activity fixed the target artifact as a governance framework operationalizing one primary obligation per layer—an access boundary at Bronze, a quality gate at Silver, and a sensitivity-aware transformation at Gold—together with three cross-layer obligations for ownership, lineage, and audit trail, rather than a policy layer applied above the Medallion pattern. The design and development activity produced the per-layer and cross-layer obligation specifications presented in Sections 3.2 through 3.5, together with the six-mode failure taxonomy presented in Section 4.1, each derived by mapping the regulatory requirements identified during problem identification onto the corresponding Medallion layer or cross-layer relationship.

The demonstration activity took the form of structured mapping of each framework component against the technical safeguard standards of HIPAA (45 C.F.R. § 164.312), NIST SP 800-53 Rev. 5 control families, the FTC Safeguards Rule (16 C.F.R. Part 314), and GDPR Article 5 (Section 4.2), together with a worked governance retrofit sequence (Section 4.3); demonstration in this study denotes structured regulatory-requirement mapping rather than a live pilot deployment, and no claim of empirical validation in a production environment is made. The evaluation activity assessed the framework against the completeness of regulatory coverage achieved (Section 4.2) and against the six-mode failure taxonomy synthesized from practitioner experience in regulated data platform environments (Section 4.1), which functions in this research as a diagnostic evaluation criterion rather than as a statistically validated empirical finding, a scope boundary Section 4.4 states explicitly. The framework is technology-agnostic at the

principle level; where cloud-native implementation examples are required, Amazon Web Services (AWS) Lake Formation and Amazon S3 are referenced as representative instances. The communication activity is represented by this article: Section 2 situates the problem in prior literature, Sections 3.2 through 3.5 present the framework design, Section 4 presents the demonstration, evaluation, and implementation pathway, and Section 5 concludes.

3.2 Bronze as an Access Boundary

Among the three Medallion layers, Bronze is the most sensitive by design—no redaction, masking, aggregation, or classification-based filtering has been applied, and the layer holds every record exactly as received. This characteristic, which makes Bronze valuable as a faithful ingestion record, simultaneously makes its access boundary the most consequential in the architecture. The standard Medallion description leaves this boundary undefined.

Read access to Bronze is limited to an explicitly named set of principals: ingestion pipelines executing under service accounts scoped to the Bronze storage partition; data engineers directly responsible for those pipelines, authorized by role attribute rather than individual identity; and privacy and security personnel who require raw record access for incident investigation. Business analysts, program staff, and data scientists are excluded by default—not on grounds of trust, but on grounds that their legitimate downstream needs are served by Silver and Gold once those layers are mature. The taxonomy is implemented through attribute-based access control [27] enforced at the storage layer. Access authorization and enforcement under 45 C.F.R. § 164.312(a) are supported through role-attribute assignment [6], with unique user identification maintained via individual service-account and personnel identifiers layered beneath each role. Figure 1 shows the access control architecture of the Bronze layer.

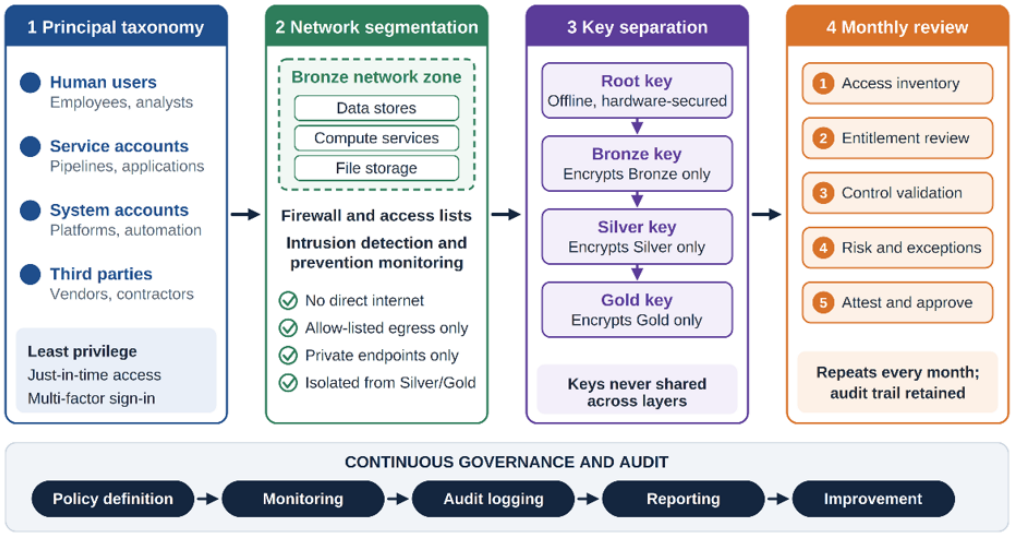


Figure 1. Bronze layer access control architecture: principal taxonomy, network segmentation, key hierarchy separation, and monthly review cycle

Bronze records are stored immutably, including malformed records. A silent record drop at ingestion creates an audit deficiency: the organization cannot demonstrate fidelity to a regulator if the raw received state is not preserved. Source attribution is maintained at the record level—which source system, which extraction run identifier, and which timestamp—stored as record metadata rather than in a separate system. This structure provides the chain-of-custody requirement: the provenance of each Bronze record is reconstructible from the record itself.

Storage-layer encryption with key material separate from the Silver and Gold key hierarchy prevents a downstream credential compromise from extending to Bronze. Network segmentation prevents direct query tool connections without privileged access elevation. Access policy review cadence is monthly rather than annual—calibrated to the observed pattern in regulated data platform engagements at which access exceptions accumulate and solidify into defaults.

3.3 Silver as a Quality Gate

Where Bronze preserves data exactly as received, Silver is the layer at which the organization decides what it is willing to assert about the data it serves to downstream consumers. That decision—and the evidence that supports it—is the governance obligation the standard Medallion description leaves unnamed.

Each Silver dataset is governed by an explicit quality contract: a documented, signed statement of what the dataset claims about itself, enforceable by the pipeline and retained in the data catalog as a governance artifact. As shown in

Table 2, the contract covers five dimensions synthesized from the quality literature [17, 18, 20]: schema conformance; referential integrity; completeness with documented late-arrival handling; timeliness monitored against a defined service expectation; and column-level sensitivity classification enforceable by downstream access control. A Silver dataset without a signed contract is an unasserted Bronze dataset in the wrong partition.

Table 2. Silver quality contract: five dimensions, definitions, validation logic, and compliance references

Dimension	Definition	Validation Logic	Compliance Reference
Schema conformance	All fields match the registered schema; no unexpected nulls in mandatory columns	Schema registry comparison at promotion time; hard-fail on deviation	NIST SI-10; HIPAA, 45 C.F.R. § 164.312(c)
Referential integrity	Foreign key relationships to reference datasets hold; no orphaned records	Join validation against reference data at promotion; orphan to exception store	HIPAA, 45 C.F.R. § 164.312(c)
Completeness	Required fields populated above threshold; late-arrival window documented	Null-rate check per column against threshold; late-arrival service-level agreement logged	Weiskopf and Weng [20]; NIST SI-10
Timeliness	Data arrives and is promoted within a defined service-level window	Promotion timestamp vs. source extraction timestamp; service-level agreement breach to alert	Wang and Strong [17]; FTC Safeguards Rule, 16 C.F.R. Part 314
Sensitivity classification	Every column bears a sensitivity class (personally identifiable information, protected health information, confidential, or public)	Catalog classification check; unclassified columns block promotion	HIPAA Minimum Necessary Standard; GDPR Art. 5; FTC §314

Note: HIPAA = Health Insurance Portability and Accountability Act; NIST = National Institute of Standards and Technology; GDPR = General Data Protection Regulation; FTC = Federal Trade Commission; SI = System and Information Integrity.

Data promoted from Bronze to Silver generates a promotion evidence record capturing the validation logic executed, what passed and what failed, records routed to the exception store with failure reasons, and the pipeline identifier, version, execution timestamp, and authorizing service account identity. Automated quality constraint evaluation [19] provides the technical mechanism; the promotion evidence record provides the governance artifact supporting HIPAA, 45 C.F.R. § 164.312(b) audit control requirements [6]. Downstream reliance on Silver data is warranted because the promotion evidence record demonstrates that the quality contract was satisfied at a specific, auditable point in time.

Algorithm 1 Promotion of Bronze Data to the Silver Layer

Require: Bronze dataset $bronze_df$, quality contract $contract$

```
results ← {
    "schema_conformance": check_schema(bronze_df, contract.schema),
    "referential_integrity": check_fk(bronze_df, contract.fk_refs),
    "completeness":  check_nulls(bronze_df, contract.required_cols,
                                 contract.completeness_threshold),
    "timeliness": check_sla(bronze_df, contract.sla_window),
    "sensitivity_labels": check_classified(bronze_df, contract.sensitivity_map)
}
passed ← all(r.passed for r in results.values())
write_promotion_evidence_record(pipeline_id=PIPELINE_ID, version=PIPELINE_VERSION,
    executed_at=now(), executor=SERVICE_ACCOUNT, results=results, passed=passed)
if passed then
    silver_df ← apply_conforming_transforms(bronze_df, contract)
    write_lineage_record( source=bronze_df.lineage_id, target='silver.' + contract.dataset_name,
     transform_ref=contract.transform_version)
    return promote(silver_df, catalog_entry=contract.dataset_name)
else
    route_to_exception_store(bronze_df, results)
    return None
end if
```

The promotion evidence record and the lineage record are both produced as a side effect of the promotion call itself, not authored separately after the fact; this is what makes them auditable as engineered platform outputs consistent with the lineage-as-designed-output principle of Section 3.5, rather than reconstructed documentation of uncertain currency.

3.4 Gold as a Sensitivity-Aware Transformation Stage

The disclosure decision—what the organization is willing to reveal and to which population—is made when a Gold dataset is constructed. Standard descriptions of Gold as the business-ready consumption layer are accurate as far as they go; they do not capture that the transformations applied between Silver and Gold are regulatory decisions, not engineering optimizations, and that those decisions must be made against a specific named consumer population rather than inferred from the data's structure.

The consumer population for each Gold dataset is specified before construction begins. The same Silver source may produce multiple Gold datasets: a clinically detailed view accessible to authorized clinical users under purpose-of-use controls; a de-identified analytical view for research users under a data use agreement, produced per NIST SP 800-188 standards [25]; and a statistically aggregated public reporting view. The transformation applied in each case is governed by the specific consumer population's authorization.

Three items must be demonstrable on demand for every Gold dataset: the source Silver derivation, the transformations applied, and the consumer population the dataset was designed for. A Gold dataset subsequently accessed by a population broader than specified constitutes a compliance event under both HIPAA minimum necessary principles [6] and GDPR data minimization obligations [8]—the obligation attaches at the point of broader access, not at the point of original construction.

3.5 Cross-Layer Obligations

Ownership, lineage, and audit trail span all three layers. Each represents a property of the relationships among layers rather than a property of any individual layer, and none can be delegated to Bronze, Silver, or Gold alone.

Named ownership is maintained at each layer: the ingestion engineer or source system team at Bronze; the data steward who signed the quality contract at Silver; the business consumer whose use case the dataset was built for at Gold. A dataset without a named owner is abandoned data—in regulated environments, abandoned data at Bronze accumulates breach notification risk at a rate proportional to its sensitivity classification. Ownership is maintained in the data catalog and reviewed quarterly; change of ownership is a documented governance event. Table 3 shows the sensitivity-aware transformation catalog, while Figure 2 shows the cross-layer governance obligations overlay.

Table 3. Sensitivity-aware transformation catalog: five types, descriptions, conditions, and regulatory basis

Transformation	Description	Condition for Use	Regulatory Basis
Masking	Partial obscuring of field value; format preserved	Consumer authorized for field's sensitivity classification	HIPAA, 45 C.F.R. § 164.512; NIST SP 800-188
Tokenization	Field replaced with deterministic token; referential integrity preserved	The consumer needs to link records across datasets but not to see the original value (e.g., a medical record number replaced by a token that preserves join keys)	NIST SP 800-188; GDPR Article 5
Generalization	Precise values replaced with broader categories (e.g., exact age $\rightarrow$ age-band)	Cross-dataset analysis required; individual identity must remain controlled	HIPAA Safe Harbor; NIST SP 800-188
Suppression	Fields or rows removed where rare-value combinations create re-identification risk	De-identified analytical datasets; population-level analysis	NIST SP 800-188; GDPR Article 25
Aggregation	Individual records replaced with summary statistics	Residual risk after generalization; small-cell suppression	HIPAA Minimum Necessary Standard; GDPR Art. 5

Note: HIPAA = Health Insurance Portability and Accountability Act; NIST = National Institute of Standards and Technology; SP = Special Publication; GDPR = General Data Protection Regulation.

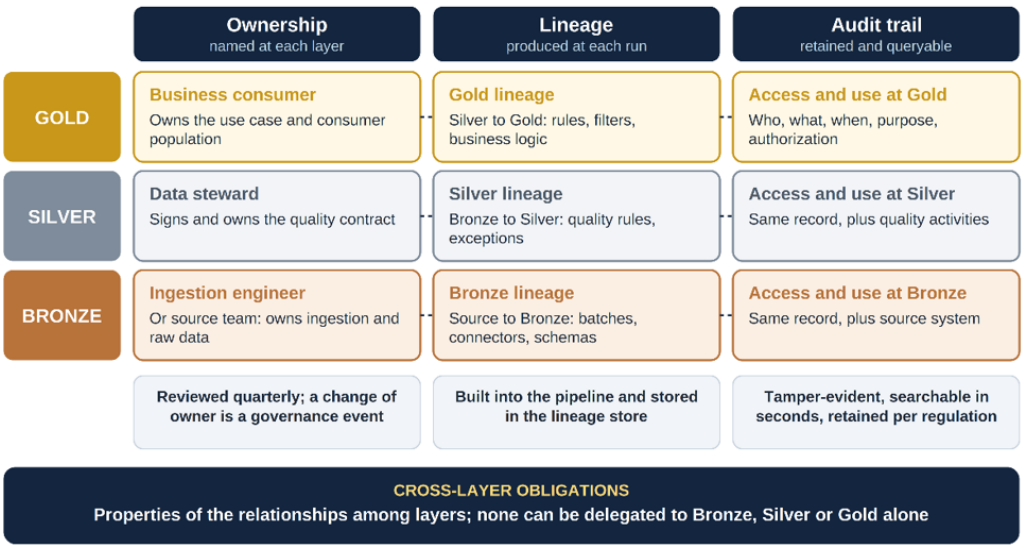


Figure 2. Cross-layer governance obligations overlay: ownership assignment, lineage pipeline integration, and audit trail retention across Bronze-Silver-Gold

Data lineage is produced by the pipeline infrastructure as a designed output at each execution, not assembled from engineering documentation after the fact. The distinction is consequential: an auditor's question about data origin is answerable in seconds from a lineage query, not in days from a manual trace through documentation that may or may not reflect the current pipeline state [11]. HIPAA 45 C.F.R. § 164.312(b) audit control requirements for data-origin queries are supported by the lineage store [6].

The regulated data platform's audit trail is an intentional deliverable capturing who accessed which dataset at which layer, at what time, for what stated purpose, and under which authorization. Retention periods are calibrated to applicable regulatory requirements—HIPAA specifies a minimum six-year retention for supporting documentation [6]; NIST SP 800-53 AU-11 specifies retention calibrated to legal hold obligations [15]. The trail is tamper-evident and queryable at response times that make it practically useful in an audit or incident investigation; technical compliance with a trail that requires days to query does not satisfy the practical standard regulators apply.

4 Results and Discussion

4.1 Failure Mode Analysis

Six failure modes were synthesized from practitioner experience and observed patterns in regulated data platform environments, presented as informed practitioner judgment rather than as statistically validated findings. Each has a structural cause and a structural remedy. Table 4 summarizes the full taxonomy; the following paragraphs characterize each mode.

Failure Mode 1 — The Permeable Bronze Boundary: Read access exceptions at Bronze accumulate as early operational expediencies harden into defaults. When downstream layers are not yet production-ready, broader access is granted temporarily; no review process exists to prompt revocation when those layers mature. Monthly access review at Bronze—with the justification burden on retention rather than revocation—addresses the structural cause.

Failure Mode 2 — Silver Without a Contract: Absence of an explicit quality contract makes it impossible to answer, in an audit or incident investigation, what a Silver dataset guarantees about itself. The structural remedy is a pipeline deployment gate: no dataset may be promoted to Silver without a signed contract and a named steward.

Failure Mode 3 — Gold Built for Reuse, Not a Population: Sensitivity-aware transformations calibrated to the broadest plausible audience rather than a specific named consumer population create silent compliance events when additional, differently authorized teams access the dataset. A named consumer population requirement in every Gold specification, with population change treated as a governance event, addresses the structural cause.

Failure Mode 4 — Lineage as Afterthought: Treating lineage as a documentation deliverable rather than an engineered pipeline output produces a record that is incomplete from the platform's first production day and unverifiable during audit. Lineage instrumented in pipeline code from the first sprint, measured as a completeness metric, addresses the root cause.

Failure Mode 5 — The Cataloging Gap: The absence of a maintained catalog at each layer means the organization cannot answer what sensitive data it holds and where without manual storage enumeration. Catalog entry as a required pipeline definition output—not a documentation phase deliverable—is the structural remedy.

Failure Mode 6 — Stewardship Vacancy: Pipelines continue to run and consumers continue to rely on data after the steward who signed the quality contract departs without designating a successor. Stewardship succession as a standard offboarding obligation, with vacancy treated as a critical compliance gap reported to the data governance program, is the structural remedy.

Table 4. Failure mode analysis: structural cause, observable indicator, and structural remedy for six regulated deployment failure modes

Failure Mode	Structural Cause	Observable Indicator	Structural Remedy
Permeable Bronze Boundary	Access exceptions granted during platform build-out are never revoked	Bronze read access held by business analyst or data scientist accounts	Monthly access review; retention must be actively justified
Silver Without a Contract	Quality contract not required as a pipeline deployment prerequisite	The audit question "What does this dataset guarantee?" produces no answer	Pipeline deployment gate: contract + steward required before promotion
Gold Built for Reuse	Gold datasets designed for the broadest plausible audience, not the named population	Multiple teams with different authorizations accessing the same Gold dataset	Named consumer population in every Gold specification; reuse = governance event
Lineage as Afterthought	Lineage planned as a documentation deliverable rather than an engineered output	The lineage record does not reflect the current pipeline configuration at audit	Lineage instrumented in pipeline code from sprint 1; completeness measured
Cataloging Gap	Catalog maintenance deferred to a documentation phase that never arrives	Organization cannot enumerate sensitive assets without manual storage scans	Catalog entry required as a pipeline definition output at deployment
Stewardship Vacancy	Steward departs without a designated successor; no offboarding requirement	The Silver dataset quality contract has no named accountable owner	Stewardship succession required at offboarding; vacancy = critical gap

4.2 Regulatory Compliance Mapping

Structured mapping against HIPAA Security Rule technical safeguard standards indicates that the framework's components address each required implementation specification examined below. Access control obligations under 45 C.F.R. § 164.312(a) are supported at three levels: the Bronze access principal taxonomy addresses access authorization and enforcement through role-attribute assignment [27], with unique user identification maintained via individual service-account and personnel identifiers layered beneath each role; monthly attribute-based access control policy review addresses access establishment and modification; and the separate Bronze encryption key hierarchy addresses encryption and decryption [6].

Audit control obligations under 45 C.F.R. § 164.312(b) are supported collectively by the Silver promotion evidence record, the Gold derivation audit record, and the cross-layer audit trail—together enabling post-hoc reconstruction of any data access pathway from source system to consumer endpoint. Integrity control under 45 C.F.R. § 164.312(c)(1) is supported by the Silver quality contract's validation logic and by the Bronze immutability model.

Mapping against NIST SP 800-53 Rev. 5 indicates strong alignment across the Access Control (AC), Audit and Accountability (AU), and System and Information Integrity (SI) control families [15]. AC-2 and AC-3 are addressed by the Bronze access taxonomy; AU-2, AU-3, and AU-9 by the promotion evidence record and cross-layer audit trail; SI-10 by the quality contract's schema conformance and referential-integrity checks; and SI-7 by the Bronze immutability model. The FTC Safeguards Rule data classification requirement [7] is operationalized through the Gold transformation catalog's column-level classification-governed transformation logic. GDPR data minimization and purpose limitation (Article 5) [8] are operationalized through the consumer-population-governed transformation specification and the Gold audit obligation's requirement that population reuse constitute a compliance event.

4.3 Implementation Pathway

Figure 3 shows the Gold-first governance retrofit pathway. Starting at Gold rather than Bronze is the counterintuitive recommendation this framework makes, grounded in change-management research rather than in platform-specific empirical evidence. Kotter's analysis of large-scale organizational change identifies the absence of visible short-term wins as a primary reason transformation efforts fail [28]: initiatives that defer all visible results to a late implementation stage lose the stakeholder sponsorship needed to sustain them. Applied to governance retrofit, this predicts that business stakeholders who authorize governance investment respond to improvements that are visible to them; Gold datasets—the layer most directly accessed by analysts and reporting consumers—provide that visibility, while Bronze access tightening produces no visible business analytics change and risks generating compliance fatigue before governance work reaches the layers that matter most operationally.

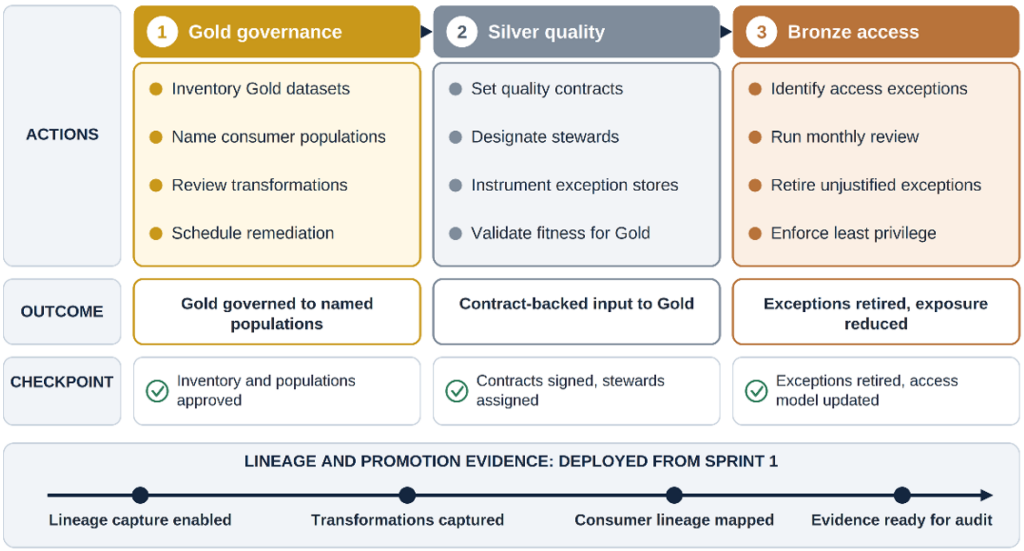


Figure 3. Gold-first governance retrofit pathway: three-stage implementation sequence with governance event checkpoints and lineage instrumentation timeline

In practice, the sequence proceeds as follows. Existing Gold datasets are inventoried; named consumer populations are identified or designated; transformations currently applied are reviewed against those populations' authorizations; and mismatches are scheduled as prioritized remediation items. Silver quality contracts are then established for the Silver datasets feeding each well-governed Gold use case: stewards are designated, and exception stores are instrumented. Bronze access exceptions are retired through the monthly review cycle—they lose their downstream justification once Silver and Gold are disciplined, reducing organizational resistance to their revocation. Throughout all three stages, lineage instrumentation and promotion evidence records are deployed as designed pipeline outputs from the first sprint, not deferred to a later phase.

4.4 Limitations

Three scope boundaries apply. The framework was designed for single-tenant lakehouse configurations; multi-tenant architectures require tenant isolation mechanisms beyond what is specified in this study. The Bronze provenance preservation specification requires source systems to emit record-level source attribution at ingestion; legacy source systems without record-level metadata require ingestion-stage remediation before the Bronze specifications are fully auditable. The Gold transformation catalog references NIST SP 800-188 de-identification standards [25] as its technical basis; organizations operating under GDPR pseudonymization requirements may need to adapt the catalog accordingly.

5 Conclusions

Governance obligations have always been implicit in the Medallion Architecture—Bronze always carried access risk, Silver always carried quality assertion responsibility, and Gold always carried disclosure responsibility. What the standard description omitted was naming those obligations and specifying them as infrastructure requirements. The compliance-first framework developed in this study names them, operationalizes them per layer, and evaluates them against the four regulatory instruments most relevant to regulated enterprise data platform environments: the HIPAA Security Rule, NIST SP 800-53 Rev. 5, the FTC Safeguards Rule, and the GDPR.

The primary contribution—operationalizing governance obligations within the Medallion pattern rather than above it—produces an architecture in which Bronze access control, Silver quality assertion, and Gold disclosure decision are enforced by the platform infrastructure rather than by periodic policy review. That distinction separates an architecture that merely asserts support for compliance from one whose compliance-relevant controls are built into the platform and can be inspected; this study assesses that design through regulatory mapping rather than operational deployment. The six-mode failure taxonomy is the secondary contribution: operational diagnostic criteria derived from practitioner experience in regulated data platform environments, each with a structural cause and a structural remedy. The Gold-first implementation pathway translates the framework into a governance retrofit sequence calibrated to how organizations actually make and sustain governance investment decisions.

Three directions merit priority in future research: extension of the framework to multi-tenant lakehouse architectures, where cross-entity minimum necessary obligations require tenant isolation mechanisms not addressed in this study; the application of the governance reframing to lakehouse platforms serving artificial intelligence model training workloads, where what may be exposed to a model at each layer is the dominant governance question; and standardization of Silver quality contracts across organizations operating under common regulatory regimes, enabling interoperable data exchange without per-pair governance negotiation.

Data Availability

Not applicable.

Conflicts of Interest

The author declares no conflicts of interest.

Declaration on the Use of Generative AI and AI-assisted Technologies

Generative AI tools were used to assist with language editing and formatting during manuscript preparation. The author reviewed and edited all content and takes full responsibility for the accuracy, originality, and integrity of the published article.

References

[1] M. Zaharia, A. Ghodsi, R. Xin, and M. Armbrust, "Lakehouse: A new generation of open platforms that unify data warehousing and advanced analytics," in *Proceedings of the 11th Conference on Innovative Data Systems Research (CIDR)*, 2021. https://www.cidrdb.org/cidr2021/papers/cidr2021_paper17.pdf

[2] M. Armbrust, T. Das, L. Sun, B. Yavuz, S. Zhu, M. Murthy, J. Torres, H. van Hovell, A. Ionescu, A. Luszczak *et al.*, "Delta Lake: High-performance ACID table storage over cloud object stores," *Proc. VLDB Endow.*, vol. 13, no. 12, pp. 3411–3424, 2020. https://doi.org/10.14778/3415478.3415560

[3] P. Sawadogo and J. Darmont, "On data lake architectures and metadata management," *J. Intell. Inf. Syst.*, vol. 56, no. 1, pp. 97–120, 2021. https://doi.org/10.1007/s10844-020-00608-7

[4] R. Hai, C. Koutras, C. Quix, and M. Jarke, "Data Lakes: A survey of functions and systems," *IEEE Trans. Knowl. Data Eng.*, vol. 35, no. 12, pp. 12 571–12 590, 2023. https://doi.org/10.1109/TKDE.2023.3270101

[5] I. Terrizzano, P. Schwarz, M. Roth, and J. E. Colino, "Data wrangling: The challenging journey from the wild to the lake," in *Proceedings of the 7th Conference on Innovative Data Systems Research (CIDR)*, California, USA, 2015. https://www.cidrdb.org/cidr2015/Papers/CIDR15_Paper2.pdf

[6] U.S. Department of Health and Human Services, "Health insurance portability and accountability act security rule," Technical Report 45 C.F.R. §164.312, 2003.

[7] Federal Trade Commission, "Standards for safeguarding customer information," Technical Report 16 C.F.R. Part 314 (FTC Safeguards Rule), 2023.

[8] European Parliament and Council of the European Union, "General data protection regulation," 2016, regulation (EU) 2016/679.

[9] F. Nargesian, E. Zhu, R. J. Miller, K. Q. Pu, and P. C. Arocena, "Data lake management: Challenges and opportunities," *Proc. VLDB Endow.*, vol. 12, no. 12, pp. 1986–1989, 2019. https://doi.org/10.14778/3352063.3352116

[10] I. Alhassan, D. Sammon, and M. Daly, "Data governance activities: An analysis of the literature," *J. Decis. Syst.*, vol. 25, no. sup1, pp. 64–75, 2016. https://doi.org/10.1080/12460125.2016.1187397

[11] M. Herschel, R. Diestelkämper, and H. Ben Lahmar, "A survey on provenance: What for? What form? What from?" *VLDB J.*, vol. 26, no. 6, pp. 881–906, 2017. https://doi.org/10.1007/s00778-017-0486-1

[12] DAMA International, *DAMA-DMBOK: Data Management Body of Knowledge*. Technics Publications, 2017.

[13] M. Zaharia, R. S. Xin, P. Wendell, T. Das, M. Armbrust, A. Dave, X. Meng, J. Rosen, S. Venkataraman, M. J. Franklin *et al.*, "Apache Spark: A unified engine for big data processing," *Commun. ACM*, vol. 59, no. 11, pp. 56–65, 2016. https://doi.org/10.1145/2934664

[14] C. Giebler, C. Gröger, E. Hoos, H. Schwarz, and B. Mitschang, "Leveraging the data lake: Current state and challenges," in *Big Data Analytics and Knowledge Discovery*. Springer, 2019, pp. 179–188. https://doi.org/10.1007/978-3-030-27520-4_13

[15] National Institute of Standards and Technology, "Security and privacy controls for information systems and organizations," NIST Special Publication 800-53 Rev. 5, 2020. https://doi.org/10.6028/NIST.SP.800-53r5

[16] W. N. Price and I. G. Cohen, "Privacy in the age of medical big data," *Nat. Med.*, vol. 25, no. 1, pp. 37–43, 2019. https://doi.org/10.1038/s41591-018-0272-7

[17] R. Y. Wang and D. M. Strong, "Beyond accuracy: What data quality means to data consumers," *J. Manag. Inf. Syst.*, vol. 12, no. 4, pp. 5–33, 1996. https://doi.org/10.1080/07421222.1996.11518099

[18] C. Batini, C. Cappiello, C. Francalanci, and A. Maurino, "Methodologies for data quality assessment and improvement," *ACM Comput. Surv.*, vol. 41, no. 3, pp. 1–52, 2009. https://doi.org/10.1145/1541880.1541883

[19] S. Schelter, D. Lange, P. Schmidt, M. Celikel, F. Biessmann, and A. Grafberger, "Automating large-scale data quality verification," *Proc. VLDB Endow.*, vol. 11, no. 12, pp. 1781–1794, 2018. https://doi.org/10.14778/3229863.3229867

[20] N. G. Weiskopf and C. Weng, "Methods and dimensions of electronic health record data quality assessment: Enabling reuse for clinical research," *J. Am. Med. Inform. Assoc.*, vol. 20, no. 1, pp. 144–151, 2013. https://doi.org/10.1136/amiajnl-2011-000681

[21] A. Goedegebuure, I. Kumara, S. Driessen, D. Di Nucci, G. Monsieur, W. J. van den Heuvel, and D. A. Tamburri, "Data mesh: A systematic gray literature review," *ACM Comput. Surv.*, vol. 57, no. 1, pp. 11:1–11:36, 2025. https://doi.org/10.1145/3687301

[22] A. A. Harby and F. H. Zulkernine, "Data lakehouse: A survey and experimental study," *Inf. Syst.*, vol. 127, p. 102460, 2025. https://doi.org/10.1016/j.is.2024.102460

[23] National Institute of Standards and Technology, "Artificial intelligence risk management framework (AI RMF 1.0)," NIST AI 100-1, 2023. https://doi.org/10.6028/NIST.AI.100-1

[24] Organisation for Economic Co-operation and Development, "Emerging privacy-enhancing technologies: Current regulatory and policy approaches," OECD Publishing, Paris, Tech. Rep. 351, 2023. https://doi.org/10.1787/bf121be4-en

[25] National Institute of Standards and Technology, "De-identifying government datasets: Techniques and governance," NIST Special Publication 800-188, 2023. https://doi.org/10.6028/NIST.SP.800-188

[26] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *J. Manag. Inf. Syst.*, vol. 24, no. 3, pp. 45–77, 2007. https://doi.org/10.2753/MIS0742-1222240302

[27] V. C. Hu, D. Ferraiolo, R. Kuhn, A. Schnitzer, K. Sandlin, R. Miller, and K. Scarfone, "Guide to attribute based access control (ABAC): Definition and considerations," National Institute of Standards and Technology, NIST Special Publication 800-162, 2014. https://doi.org/10.6028/NIST.SP.800-162

[28] J. P. Kotter, "Leading change: Why transformation efforts fail," *Harv. Bus. Rev.*, vol. 73, no. 2, pp. 59–67, 1995. https://hbr.org/1995/03/leading-change-why-transformation-efforts-fail-2